

응용프로그램보안 지침



주식회사 모인

개정 이력

[illegible]

응용프로그램 보안지침

소관부서 : 정보보안팀

제1장 총칙

제1조(목적) 이 지침은 주식회사 모인(이하 "회사"라 한다)의 응용프로그램 개발 및 유지보수, 운영에 있어 필요한 보안 관련 활동 정의를 목적으로 한다.

제2조(적용 범위) 이 지침은 회사 내의 응용프로그램 개발 및 운영을 수행하는 임직원에게 적용한다.

제3조(용어의 정의) 이 지침에서 사용하는 용어의 정의는 다음과 같다.

1. "응용프로그램"이란 서버 등 컴퓨터에 의해 실무처리 등에 적합한 특정 업무를 수행하는 응용프로그램을 의미하며, 고객 서비스를 위하여 개발된 웹 서비스, 어플리케이션, 회사내 업무지원을 위하여 개발된 웹 페이지 등이 포함된다.
2. "프로그램 소스 관리툴(형상관리 도구)"이란 응용프로그램 개발·변경 시 생성되는 소스코드의 변경 과정을 체계적으로 관리하고 권한에 따라 접근 가능한 사용자를 통제하기 위한 도구를 의미한다.
3. "패키지 프로그램"이란 자체 목적을 가지고 제조사에서 개발한 프로그램으로 회사가 라이선스 구입 및 설치를 통해 바로 사용 가능한 프로그램을 의미하며, 패키지 프로그램에 대해 커스터마이징 또는 테일러링(Tailoring)을 통해 기능 및 요구사항을 프로그램에 반영할 수 있다.
4. "커스터마이징(Customizing)"이란 패키지 프로그램을 제조사의 개발 방법 또는 개발 도구를 이용한 코딩을 통해 회사가 요구하는 기능을 개발하는 것을 의미한다.
5. "테일러링(Tailoring)"이란 패키지가 제공하는 기능(Utility)을 이용하여 회사가 요구하는 기능을 코딩 없이 구현하는 것을 의미한다.
6. "SW 임치계약(Escrow)"란 소프트웨어 거래 시 제조사가 소스코드 및 기술정보 등을 신뢰성 있는 제3의 기관에 임치해 두고, 폐업 또는 소스코드의 멸실 등으로 유지보수를 계속할 수 없는 경우 제3의 기관이 사용자에게 소스코드 및 기술정보를 제공할 수 있도록 하는 계약을 의미한다.
7. "개인정보처리시스템"이란 개인정보를 처리할 수 있도록 체계적으로 구성한 데이터베이스 등의 시스템을 말한다.

제2장 역할 및 책임

제4조(시스템 개발관리자) 시스템 개발관리자는 응용프로그램 개발 및 운영을 관리하는 전문성을 갖춘 자로서 지침에 규정된 사항을 적절히 이행하도록 관리할 책임과 권한을 가진다.

제5조(시스템 개발자) 시스템 개발자는 응용프로그램 개발 및 운영을 수행하는 전문성을 갖춘 자로서 지침에 규정된 사항을 적절히 준수하여야 한다.

제6조(정보보호 담당자)

- 1 정보보호 담당자는 개발이 완료된 응용프로그램이 요건을 만족하도록 개발하였는지 검수하며,

- 응용프로그램이 안전하게 운영될 수 있도록 보안관리의 책임을 가진다.
- 2 정보보호 담당자는 개발 및 운영 중인 응용프로그램을 보호하는데 협조하여야 하며, 암호화와 같은 응용프로그램 보안기능의 관리를 지원하여야 한다.
 - 3 정보보호 담당자는 응용프로그램 개발 및 운영 시 정보보호 통제 실행을 관리 및 감독하여야 한다.

제3장 응용프로그램 개발 절차

제7조(개발환경 구성) 회사의 개발시스템 및 테스트시스템은 운영시스템과 물리적 또는 논리적으로 분리되어야 하며 불필요한 프로그램 및 서비스를 제거하여야 한다.

제8조(보안 요구사항 분석)

- 1 시스템 개발자는 응용프로그램의 신규 개발 또는 변경을 위한 업무 시 정보보호 담당자와 협의하여 보안성 검토 및 자체 보안성 심의 대상 여부를 확인하고 보안 요구사항을 정의하여야 한다.
- 2 시스템 개발자는 다음 각 호의 보안 기능 적용 여부를 검토하여 보안 요구사항에 반영하여야 한다.
 - 1) 사용자 인증: 인증 절차, 패스워드, 접근통제 등
 - 2) 저장 및 송·수신 시 암호화: 중요정보에 대한 암호화 대상 및 방법
 - 3) 보안로그 기능: 접속기록, 권한이력, 가동기록 등 로그 기록
 - 4) 접근권한 기능: 응용프로그램 내 단위 기능, 메뉴별 권한 등 접근권한
 - 5) 그 밖에 응용프로그램 및 데이터와 관련한 보안이 필요한 사항
- 3 시스템 개발자는 기존 시스템과의 연계성, 운영 현황 등을 고려하여 요구사항에 반영하여야 한다.
- 4 시스템 개발관리자는 보안 요구사항이 설계, 구현, 테스트, 이관 단계마다 일관성 있게 적용될 수 있도록 관리하여야 한다.

제9조(설계 단계)

- 1 시스템 개발자는 응용프로그램 설계 시 보안 요구사항에서 정의한 보안기능을 설계서에 반영하여야 한다.
- 2 시스템 개발자는 추가 적용하고자 하는 보안 기능이 있을 경우, 정보보호 담당자와 협의하여 반영하여야 한다.

제10조(구현 단계)

- 1 시스템 개발자는 응용프로그램 개발 시 안전한 코딩 기준에 따라 개발하여야 하며, 신뢰할 수 있는 개발 도구나 검증된 기술들을 적용하여야 한다.
- 2 응용프로그램 개발 시 보안 정책을 우회할 수 있거나 응용프로그램 자체 기능에 위협을 줄 수 있는 악성코드의 삽입은 금지되어야 한다.
- 3 시스템 개발자는 응용프로그램 변경 필요 시 해당 프로그램을 개발 또는 테스트 시스템으로 복사 후 수정해야 한다.
- 4 시스템 개발자는 개발된 소스코드에 대한 취약점 점검을 수행하여야 하며, 발견된 취약점은 제거하여야 한다.

제11조(테스트 단계)

- 1 정보보호 담당자는 설계 시 정의한 보안 요구사항이 반영되었는지 확인하고 보안성심의 대상에 해당하는 경우 자체 보안성심의를 실시하여야 한다. 이 경우 보안성심의 절차 및 수행은 「정보보안 점검 지침」에서 정한 바를 준용한다.
- 2 회사의 모든 응용프로그램은 운영환경에 설치하기 전에 처리하는 정보의 기밀성·무결성·가용성을

- 고려하여 충분한 테스트 과정 및 책임자의 승인을 거쳐야 한다.
- 3 시스템 개발자는 보안테스트를 수행하고 테스트에 대한 결과를 문서화하여야 한다.
 - 4 시스템 개발자는 운영 단계로 이관하기 전에 운영 매뉴얼을 작성하여야 한다. 운영 매뉴얼에는 응용프로그램에 적용된 보안 관련 사항이 포함되어야 한다.
 - 5 시스템 개발자는 운영 단계로 이관하기 전에 공식화된 접근 권한을 제외한 접근 권한을 제거하여야 한다.
 - 6 회사의 테스트 환경에 대한 접근통제는 운영환경과 동일한 접근통제가 적용되어야 한다.

제12조(이관 단계)

- 1 정보보호 담당자는 보안요구사항에 대하여 시스템 개발자의 검수가 충분히 이뤄진 것을 확인하여야 한다.
- 2 시스템 개발관리자는 발견된 취약점에 대한 조치가 완료된 것을 확인한 후 응용프로그램 이관을 승인하고 이관 담당자를 지정하여 운영환경에 적용하여야 한다. 다만, 이관 담당자는 해당 프로그램 시스템 개발자 이외의 자로 지정하여야 한다.
- 3 이관 담당자는 응용프로그램을 적용한 후, 기존의 운영 환경에 미치는 영향을 분석하고, 이상이 발생할 경우 즉시 이전 상태로 복원하여야 한다.
- 4 컴파일러, 편집기 등과 같이 개발에 필요한 도구는 운영환경에 설치를 금지하며, 실행에 필요한 파일만 설치하여야 한다.

제4장 응용프로그램 보안 통제

제13조(응용프로그램 일반 통제)

- 1 시스템 개발자는 응용프로그램 개발 보안에 필요한 교육을 주기적으로 이수하여야 한다.
- 2 회사의 모든 응용프로그램은 개발과 유지보수를 담당하는 사람을 지정하여 관리되어야 한다.
- 3 시스템 개발자는 사용자 권한과 법적 요구사항에 따라 중요정보의 필요한 부분만 표시되도록 하여, 중요정보의 노출을 통제하여야 한다.
- 4 응용프로그램의 계정 및 권한과 관련한 사항은 「계정관리 지침」에서 정한 바를 준용한다.

제14조(전자금융거래 프로그램)

- 1 회사의 전자금융거래 프로그램을 이용하여 전자금융거래 시 송·수신되는 모든 정보는 암호화하여 전송되어야 한다. 다만, 전용회선을 설치하여 정보를 송·수신하는 경우로써 자체 보안성 심의를 받은 경우에는 예외 할 수 있다.
- 2 회사의 전자금융거래 프로그램 개발 시에는 해킹이나 악성코드 감염 등에 의한 위·변조를 예방하기 위하여 프로그램의 무결성을 검증할 수 있는 기능이 포함되어야 한다.
- 3 회사의 전자금융거래 프로그램은 개발 및 테스트가 완료된 후 운영시스템에 반영하기 전에 기술 취약점 점검 등을 통해 프로그램에 대한 보안성을 검토하여야 한다.

제15조(인증수단의 선정)

- 1 전자금융거래 시 거래인증수단은 안전성, 보안성, 편의성 등을 충분히 고려하고, 전자금융거래의 종류, 성격, 위험수준 등에 따라 안전한 인증방법으로 선정되어야 한다.
- 2 비대면 실명인증 방식은 「금융실명거래 및 비밀보장에 관한 법률」에 따른 비대면 실명확인 방식을 준수하는 방법으로 선정되어야 한다.

제16조(외부자 개발보안) 외부자에 대한 보안관리 및 계약 등과 관련한 사항은 「외부주문 보안지침」에서 정한 바를 준용한다.

제17조(접근통제)

- 1 응용프로그램에 저장된 정보의 중요도가 다양할 경우, 프로그램 내의 가장 중요한 정보를 기준으로 보안통제가 이루어져야 한다.
- 2 응용프로그램은 서비스 단위별(단위 기능, 페이지 등)로 접근통제를 구현하여야 하며, 해당 서비스와 관계없는 사용자의 접근을 제한하여야 한다.
- 3 관리자 전용 응용프로그램(관리자 웹 페이지, 관리콘솔 등)은 비인가자가 접속할 수 없도록 접근통제를 하여야 한다.
- 4 일정 시간 동안 입력이 없는 세션은 자동으로 차단하고, 강화된 보안이 요구되는 응용프로그램의 경우에는 하나의 사용자 계정으로 여러 IP에서 동시 접속을 제한하여야 한다.

제18조(이용자 비밀번호)

- 1 응용프로그램 개발 및 운영 시 이용자 계정과 비밀번호 도용을 방지하기 위하여 다음 각 호의 사항을 준수하도록 관리하여야 한다.
 - 1) 안전한 비밀번호 작성 규칙 수립
 - (1) 영문자, 숫자, 특수기호 혼용하여 설정
 - (2) 비밀번호는 8자리 이상 20자리 이하의 길이로 구성
 - (3) 동일 문자 및 숫자 반복 3회, 연속 숫자 3개 사용 금지
 - 2) 비밀번호 입력/변경 시 마스킹 처리
 - 3) 비밀번호 분실·도난 시 본인인증 후 안전한 재발급 절차 수립(재발급을 통한 도용 방지를 위한 안전한 전송 및 로그인 후 변경 절차)
- 2 이용자의 비밀번호 입력 오류가 5회 이상 발생한 경우 즉시 해당 비밀번호를 이용한 거래를 중지시키고 본인확인 절차를 거친 후 비밀번호를 재설정하여야 한다.
- 3 제2항에 따른 비밀번호 오류 횟수는 이체 비밀번호 등 동일한 비밀번호가 다양한 전자금융거래에 공통으로 이용되는 경우 모든 전자금융거래를 합산하여 적용하여야 한다.
- 4 이용자 비밀번호는 조화가 불가능하도록 정보처리시스템에 저장 시 암호화하여야 하며, 인증을 위해 송·수신되는 경우에도 노출되지 않도록 암호화하여야 한다.

제19조(테스트 데이터 관리)

- 1 응용프로그램 테스트 시에는 임의의 테스트 데이터를 생성하여 활용하거나 운영데이터를 가공하여 사용하도록 하며, 실제 운영데이터 사용은 금지하여야 한다.
- 2 시스템 개발관리자는 운영데이터를 가공하는 경우 가공 방법에 대해서는 정보보호 담당자와 협의하여 개인식별이 불가능한 방법으로 정하여야 한다.
- 3 시스템 개발관리자는 테스트 목적으로 운영데이터가 불가피하게 필요한 경우 정보보호 담당자의 타당성 검토를 거쳐 운영데이터를 사용할 수 있으며, 운영데이터는 최소한으로 제한되고 요청 기간에 한하여 사용될 수 있도록 관리하여야 한다.
- 4 모든 테스트 데이터는 사용기간이 경과되거나 테스트가 완료된 후 삭제하여야 한다.

제20조(소스 관리)

- 1 응용프로그램 소스는 운영 중인 시스템에 저장하여 관리하는 것을 금지하며, 별도의 프로그램 소스 관리툴을 이용하여 관리하여야 한다.

- 2 시스템 개발관리자는 프로그램 소스 관리툴의 담당자를 선정하여 보안에 대한 책임과 권한을 명확히 하여야 한다.
- 3 허가된 사용자만 응용프로그램 소스에 접근할 수 있도록 통제하고 접근 기록을 남겨야 한다.
- 4 응용프로그램 소스 목록, 최종 프로그램 소스 및 데이터 라이브러리는 안전한 장소에 보관하여야 한다.
- 5 개발 또는 유지보수 중인 응용프로그램은 운영중인 응용프로그램의 소스와 분리하여 관리하여야 한다.
- 6 응용프로그램 소스의 변경 시 변경 일자, 변경 사유 등에 대하여 기록하고 프로그램 소스 관리툴을 통해 이력을 관리하여야 한다.

제21조(로그 관리)

- 1 다음 각 호에 해당하는 응용프로그램 관련 로그는 최소 1년 이상 보관하여야 한다.
 - 1) 사용자 및 관리자의 접속기록(사용자 접속기록, 수행업무, 다운로드 기록 등)
 - 2) 단말기를 통한 이용자 정보 조회 시 사용자, 사용일시, 변경·조회 내용, 접속방법
 - 3) 사용자 권한, 부여, 변경, 말소 기록(개인정보처리시스템의 경우 5년 보관)
 - 4) 응용프로그램 시작 및 중지
 - 5) 관리자 및 특수권한 사용자 수행업무 내역
 - 6) 전자금융거래기록(5년 보관)
 - 7) 기타 응용프로그램 관리 및 정보보호에 필요한 로그
- 2 5만명 이상의 개인정보를 처리하거나 고유식별정보 또는 민감정보를 처리하는 응용프로그램은 제1항 제1호의 접속기록을 2년 이상 보관하여야 한다.
- 3 기록된 로그는 변조나 삭제되지 않도록 비인가자가 접근할 수 없는 장소에 안전하게 보관하여야 한다.

제22조(패키지 프로그램 도입)

- 1 정보보호 담당자는 패키지 프로그램을 도입하는 경우 사전에 다음 각 호의 사항에 대하여 검토하여 도입 여부를 결정하여야 한다.
 - 1) 보안 기능 요구사항 반영 가능 여부
 - 2) 프로그램과 기존 시스템간 발생 가능한 보안적 이슈
 - 3) 제조사의 파산 시 프로그램의 소스코드 확보를 위한 SW 임치계약 여부
- 2 정보보호 담당자는 프로그램에서 지원하는 보안 기능에 대하여 검토하여 결과를 패키지 프로그램 도입 주관부서(이하 ‘주관부서’라 한다)에게 전달하여야 한다.
- 3 주관부서는 패키지 프로그램에서 보안기능을 지원하지 않는 경우 제조사에게 추가 개발을 요청하거나 대체 방안을 수립하여야 한다.
- 4 도입되는 패키지 프로그램은 이 지침에서 요구하는 사항 및 절차를 준수하고, 발생 가능한 취약점을 제거하여야 한다.

제23조(문서화 관리)

- 1 시스템 개발자는 운영시스템에서 사용되는 응용프로그램의 변경 사항을 문서화하여야 한다.
- 2 시스템 개발자는 업무 이관 시 받은 응용프로그램 관련 중요 정보 (응용프로세스의 설명, 절차, 데이터 구조, 인가절차 등)가 수록된 문서를 안전하게 보호한다.
- 3 비상사태에 대비하여 운영시스템 및 응용프로그램 현황(하드웨어 및 소프트웨어) 및 시스템운영지침서, 사용자매뉴얼을 문서화하여 관리해야 한다.

제24조(백업 및 복구 관리)

- 1 시스템 개발자는 중요정보와 응용프로그램을 보호하기 위해 백업을 실시해야 한다. 다만, 백업은 백업 관리담당자에게 위임할 수 있으며, 이 때 시스템 개발자는 백업 스케줄을 제시하여야 한다.
- 2 시스템 개발관리자는 응용프로그램 운영 과정에서 발생할 수 있는 장애 등에 대비하여 복구 절차를 수립하여야 한다

부칙

제1조(시행일) 이 지침의 시행일은 대표이사가 승인한 날로 한다.